

Attachment C (Technical Appendix: legal anchors, templates, metrics, and division mapping)

This appendix is informational and does not constitute legal advice.

Section-level CFR and program authority index

Federal Register notice (primary procedural authority)

- FR Doc. 2025-23641; Docket ID HHS-ONC-2026-0001; three-lever framing (regulation, reimbursement, R&D); specific question list.

ONC certification and standards (ASTP/ONC)

- 45 CFR 170.213 (USCDI)
- 45 CFR 170.215 (API standards; FHIR R4.0.1)
- 45 CFR 170.315(b)(11) (Decision Support Interventions; Predictive DSI transparency and intervention risk management)

Information blocking

- 45 CFR part 171 (information blocking framework)
- HealthIT.gov overview on enforcement and potential civil monetary penalties for certain actors
- HHS OIG information blocking enforcement authority and penalty framework

HIPAA privacy and security (OCR)

- 45 CFR part 160 (administrative requirements)
- 45 CFR part 164 (Privacy and Security Rules)
- 45 CFR 164.506 (permitted uses/disclosures for treatment, payment, operations)
- 45 CFR 164.524 (individual right of access)
- OCR enforcement process (how OCR enforces Privacy/Security Rules)

CMS payment and delivery models

- 42 CFR part 410 (Medicare Part B benefits/conditions; linkage to PFS)
- 42 CFR part 414 (Part B payment policies; coding/ancillary policies)
- CMS chronic care management FAQs (precedent for paying non-face-to-face coordination)
- CMS complexity add-on code G2211 FAQs and MLN guidance (longitudinal relationship recognition)
- 42 CFR part 425 (MSSP/ACOs; infrastructure and redesigned care processes)
- 42 CFR part 438 and 42 CFR 438.242 (Medicaid managed care health information systems)

CMS interoperability rules

- CMS-9115-F (2020 Interoperability and Patient Access final rule; patient access and payer API obligations)

- CMS-0057-F (2024 Interoperability and Prior Authorization final rule; PA modernization and API expansion)
- TEFCA (Trusted Exchange Framework and Common Agreement) as a nationwide interoperability framework intended to provide a floor for exchange across proprietary boundaries

Research ethics and human subjects protections

- 45 CFR part 46 (HHS human subjects protections / Common Rule)

Risk management and clinical AI governance frameworks

- NIST AI RMF 1.0 (NIST AI 100-1)
- FDA/IMDRF Good Machine Learning Practice (GMLP) guiding principles (total product lifecycle orientation)
- WHO guidance on ethics and governance of large multimodal models for health

Safety and burden evidence anchors

- NASEM diagnostic error estimates (baseline diagnostic error prevalence)
- NAM clinician burnout systems approach (administrative/system drivers of burnout)
- ECRI hazard on misuse of AI chatbots (non-device misuse risk)

Tribal data sovereignty and HHS consultation posture

- IHS/HHS tribal consultation posture on developing HHS tribal data sharing policy (sovereignty and trust emphasis)

Division-by-division implementation mapping

ASTP/ONC

Certified health IT requirements; Predictive DSI transparency/IRM baseline; interoperability floors (USCDI/FHIR); TEFCA coordination; information blocking coordination.

CMS

Reimbursement pathways for evaluation/implementation; incentive alignment in MA/MSSP/Medicaid managed care; API requirements and prior authorization modernization through CMS rules.

OCR

HIPAA privacy/security guidance and enforcement posture; clarifying permissible operations uses and safeguards for AI-enabled care; reinforcing enforceable access rights.

AHRQ

Implementation science; patient-centered CDS; real-world toolkits, learning networks, human factors research, equity evaluation.

IHS (and HHS tribal policy workstreams)

Tribal partnership pathways, sovereignty-respecting data stewardship standards, consultation processes, and alignment to HHS tribal data sharing policy development.

Governance templates

Template: risk-tier classification for non-device clinical AI (minimum viable)

Risk tier determined by:

- Context of use (administrative vs care operations vs clinical decision influence)
- Reversibility of harm and time sensitivity
- Degree of autonomy (recommendation vs action execution)
- Data sensitivity and longitudinal aggregation requirements
- Equity sensitivity (risk of disparate impact)
- Auditability and traceability availability
- Tie risk analysis dimensions to Predictive DSI IRM categories (validity, reliability, robustness, fairness, intelligibility, safety, security, privacy).

Template: system-level oversight charter (“on the loop”)

- Accountable executive sponsor
- Clinical safety lead (defines escalation thresholds, rollback triggers)
- Privacy/security lead (HIPAA compliance and risk analysis)
- Monitoring lead (drift, safety, equity dashboards)
- Incident response workflow and reporting cadence
- Update control and “material change” definition

Template: monitoring and escalation policy

- Define monitored signals (safety, drift, equity, burden)
- Thresholds for escalation and rollback
- Retrospective audit schedule and “learning loop” reviews
- Version change logs and post-update monitoring requirements consistent with lifecycle/GMLP principles

Model contract principles (non-device clinical AI)

These are baseline principles; parties should adapt to context.

1. Auditability and logs: access to logs sufficient to investigate incidents and reproduce outputs used in care.
2. Version transparency: disclosure of model/version changes; notice of material updates; change logs.
3. Monitoring obligations: define vendor and deployer responsibilities for drift detection and safety monitoring.
4. Purpose fidelity and secondary use boundaries: explicit permitted uses of PHI and non-PHI; no implied training/secondary use beyond agreed scope; align with HIPAA permitted uses and disclosures.
5. Interoperability and exit: open standards compliance, data portability, and transition support; align to USCDI/FHIR baseline.

6. Non-discriminatory access: avoid pricing and technical practices that create de facto lock-in or capture through unusable friction; align to information blocking posture and exceptions framework.

Evaluation metrics (minimum viable set)

Pre-deployment

- Silent-mode concordance and error characterization
- Subgroup performance and equity stratification
- Human factors: cognitive load, interpretability, alert fatigue markers
- Workflow impact (time-in-task proxies)

Post-deployment (continuous)

- Safety signal rate and severity; escalation frequency
- Drift metrics and recalibration cadence
- Equity drift monitoring
- Audit log completeness and incident investigation time
- Clinician burden: documentation time proxies, workload indicators (aligned to burnout reduction goals)

Tribal partnership and data sovereignty addendum (pilot governance)

For pilots involving tribal communities, governance should:

- Treat participation as voluntary and sovereignty-respecting
- Establish co-designed data stewardship, permissions, and use boundaries with tribes/TECs
- Align to ongoing HHS tribal data sharing policy development and consultation processes